Fracto REST API Design

Overview

This document describes the currently implemented Fracto API surface based on the live ASP.NET Core controllers and DTOs in the project.

Scope

This file focuses on endpoint contracts, request bodies, response shapes, and access rules.

- For token lifecycle, middleware validation, and frontend session behavior, see JWT_Authentication_Flow.md.
- For table design and storage constraints behind these endpoints, see Database_Design.md.

Base Path

- Local development base URL: `http://localhost:5104/api`
- All endpoints are rooted under `/api`
- Request and response format: `application/json` unless otherwise noted

Authentication Header

Protected endpoints require:

```
Authorization: Bearer <jwt-token>
```

Standard Error Shape

The API uses centralized exception handling and returns errors in this format:

```
{
  "message": "Human-readable error message."
}
```

Response Conventions

Paged Response Shape

Endpoints that return lists commonly use this envelope:

```
{
  "pageNumber": 1,
  "pageSize": 10,
  "totalRecords": 25,
  "items": []
}
```

Authorization Rules

Access Level	Meaning
Public	endpoint can be called without a token
Authenticated	valid JWT required
Admin	valid JWT required and user role must be `Admin`

Authentication APIs

POST /api/auth/register

- Access: `Public`
- Purpose: create a new user account and immediately return an authenticated session payload

Request body:

```
{
  "firstName": "Harsh",
  "lastName": "Raj",
  "email": "harsh.raj@example.com",
  "password": "StrongPassword@123",
  "phoneNumber": "9876543210",
  "city": "Bengaluru"
}
```

Success response:

```
{
  "message": "Registration successful.",
  "token": "<jwt-token>",
  "expiresAtUtc": "2026-03-20T15:30:00Z",
  "user": {
    "userId": 12,
```

```
    "fullName": "Harsh Raj",
    "email": "harsh.raj@example.com",
    "role": "User",
    "city": "Bengaluru",
    "profileImagePath": null
  }
}
```

Common failure:

```
{
  "message": "An account with this email already exists."
}
```

POST /api/auth/login

- Access: `Public`
- Purpose: authenticate a user or admin and return a session payload

Request body:

```
{
  "email": "user@fracto.com",
  "password": "User@123"
}
```

Success response:

```
{
  "message": "Login successful.",
  "token": "<jwt-token>",
  "expiresAtUtc": "2026-03-20T15:30:00Z",
  "user": {
    "userId": 2,
    "fullName": "Harsh Raj",
    "email": "user@fracto.com",
    "role": "User",
    "city": "Bengaluru",
    "profileImagePath": null
  }
}
```

Failure response:

```
{
  "message": "Invalid email or password."
}
```

GET /api/auth/me

- Access: `Authenticated`

- Purpose: return the currently authenticated user summary

Success response:

```
{
  "userId": 2,
  "fullName": "Harsh Raj",
  "email": "user@fracto.com",
  "role": "User",
  "city": "Bengaluru",
  "profileImagePath": null
}
```

PUT /api/auth/me

- Access: `Authenticated`
- Purpose: update the current user's profile information

Request body:

```
{
  "firstName": "Harsh",
  "lastName": "Raj",
  "phoneNumber": "+919876543210",
  "city": "Bengaluru"
}
```

Success response:

```
{
  "userId": 2,
  "fullName": "Harsh Raj",
  "email": "user@fracto.com",
  "role": "User",
  "city": "Bengaluru",
  "profileImagePath": null
}
```

PUT /api/auth/change-password

- Access: `Authenticated`
- Purpose: update the user's password after validating the current password

Request body:

```
{
  "currentPassword": "User@123",
  "newPassword": "NewUser@123"
}
```

Success response:

```
{
  "message": "Password updated successfully."
}
```

POST /api/auth/refresh

- Access: `Public`
- Purpose: rotate refresh token and issue a new access token
- Notes: relies on the HTTP-only refresh cookie; body is optional

Optional request body:

```
{
  "refreshToken": "<refresh-token>"
}
```

Success response:

```
{
  "message": "Session refreshed.",
  "token": "<jwt-token>",
  "expiresAtUtc": "2026-03-20T15:30:00Z",
  "user": {
    "userId": 2,
    "fullName": "Harsh Raj",
    "email": "user@fracto.com",
    "role": "User",
    "city": "Bengaluru",
    "profileImagePath": null
  }
}
```

POST /api/auth/logout

- Access: `Public`
- Purpose: revoke the refresh token and clear the cookie

Success response:

```
{
  "message": "Logged out successfully."
}
```

POST /api/auth/profile-image

- Access: `Authenticated`
- Content type: `multipart/form-data`
- Purpose: upload a profile image for the current user

Form fields:

Field	Type	Required
`file`	file	yes

Success response:

```
{
  "message": "Profile photo has been successfully updated.",
  "path": "/uploads/profiles/8dd2d4e2-4ef6-49a8-a86b-4c33f1d8f10e.png"
}
```

Specialization APIs

GET /api/specializations

- Access: `Public`
- Purpose: return active doctor specializations for search and admin forms

Success response:

```
[
  {
    "specializationId": 1,
    "specializationName": "Cardiologist",
    "description": "Heart and blood vessel specialist"
  },
  {
    "specializationId": 2,
    "specializationName": "Dermatologist",
    "description": "Skin specialist"
  }
]
```

POST /api/specializations

- Access: `Admin`
- Purpose: create a new specialization

Request body:

```
{
  "specializationName": "Orthopedic",
  "description": "Bone and joint specialist",
  "isActive": true
}
```

PUT /api/specializations/{id}

- Access: `Admin`

- Purpose: update an existing specialization

DELETE /api/specializations/{id}

- Access: `Admin`
- Purpose: deactivate a specialization

Success response:

```
{
  "message": "Specialization has been deactivated."
}
```

Doctor APIs

GET /api/doctors

- Access: `Public`
- Purpose: return a paginated list of active doctors (admins can include inactive records)

Example request:

```
GET /api/doctors?pIndex=1&pSize=10
```

Optional query parameter:

Name	Type	Required	Notes
`includeInactive`	bool	no	only honored for admin callers

Success response:

```
{
  "pageNumber": 1,
  "pageSize": 10,
  "totalRecords": 3,
  "items": [
    {
      "doctorId": 1,
      "fullName": "Dr. Ananya Mehta",
      "specializationId": 1,
      "specializationName": "Cardiologist",
      "city": "Bengaluru",
      "experienceYears": 12,
      "consultationFee": 800.0,
      "averageRating": 4.7,
      "totalReviews": 16,
      "consultationStartTime": "09:00",
      "consultationEndTime": "13:00",
      "slotDurationMinutes": 30,
```

```
      "profileImagePath": null,
      "isActive": true,
      "availableSlots": []
    }
  ]
}
```

GET /api/doctors/search

- Access: `Public`
- Purpose: search doctors by city, specialization, rating, and optional appointment date

Query parameters:

Name	Type	Required	Notes
`location`	string	no	case-insensitive exact city match
`specId`	int	no	specialization filter
`ratingFloor`	decimal	no	minimum average rating
`preferredDate`	`yyyy-MM-dd`	no	includes generated available slots
`pIndex`	int	no	default `1`
`pSize`	int	no	default `10`, clamped by backend

Example request:

```
GET /api/doctors/search?
location=Bengaluru&specId=1&ratingFloor=4.5&preferredDate=2026-03-
24&pIndex=1&pSize=12
```

Success response:

```
{
  "pageNumber": 1,
  "pageSize": 12,
  "totalRecords": 1,
  "items": [
    {
      "doctorId": 1,
      "fullName": "Dr. Ananya Mehta",
      "specializationId": 1,
      "specializationName": "Cardiologist",
      "city": "Bengaluru",
      "experienceYears": 12,
      "consultationFee": 800.0,
      "averageRating": 4.7,
```

```
      "totalReviews": 16,
      "consultationStartTime": "09:00",
      "consultationEndTime": "13:00",
      "slotDurationMinutes": 30,
      "profileImagePath": null,
      "isActive": true,
      "availableSlots": [
        { "time": "09:00", "isAvailable": true },
        { "time": "09:30", "isAvailable": true },
        { "time": "10:00", "isAvailable": true }
      ]
    }
  ]
}
```

GET /api/doctors/{id}

- Access: `Public`
- Purpose: return one active doctor by id

Success response:

```
{
  "doctorId": 1,
  "fullName": "Dr. Ananya Mehta",
  "specializationId": 1,
  "specializationName": "Cardiologist",
  "city": "Bengaluru",
  "experienceYears": 12,
  "consultationFee": 800.0,
  "averageRating": 4.7,
  "totalReviews": 16,
  "consultationStartTime": "09:00",
  "consultationEndTime": "13:00",
  "slotDurationMinutes": 30,
  "profileImagePath": null,
  "isActive": true,
  "availableSlots": []
}
```

GET /api/doctors/{id}/available-slots

- Access: `Public`
- Purpose: return open time slots for a doctor on a given date

Example request:

```
GET /api/doctors/1/available-slots?date=2026-03-24
```

Success response:

```
[
  { "time": "09:00", "isAvailable": true },
  { "time": "09:30", "isAvailable": true },
  { "time": "10:00", "isAvailable": true }
]
```

GET /api/doctors/{id}/ratings

- Access: `Public`
- Purpose: return the doctor rating summary and review list

Success response:

```
{
  "doctorId": 1,
  "averageRating": 4.7,
  "totalReviews": 16,
  "items": [
    {
      "ratingId": 21,
      "userName": "Harsh Raj",
      "ratingValue": 5,
      "reviewComment": "Very professional and explained the treatment
        clearly.",
      "createdAtUtc": "2026-03-25T09:45:00Z"
    }
  ]
}
```

POST /api/doctors

- Access: `Admin`
- Purpose: create a new doctor profile

Request body:

```
{
  "fullName": "Dr. Priya Nair",
  "specializationId": 3,
  "city": "Chennai",
  "experienceYears": 8,
  "consultationFee": 600.0,
  "consultationStartTime": "09:00:00",
  "consultationEndTime": "13:00:00",
  "slotDurationMinutes": 30,
  "profileImagePath": "/uploads/doctors/priya-nair.png",
  "isActive": true
}
```

Success response:

```
{
  "doctorId": 7,
  "fullName": "Dr. Priya Nair",
  "specializationId": 3,
  "specializationName": "Dentist",
  "city": "Chennai",
  "experienceYears": 8,
  "consultationFee": 600.0,
  "averageRating": 0,
  "totalReviews": 0,
  "consultationStartTime": "09:00",
  "consultationEndTime": "13:00",
  "slotDurationMinutes": 30,
  "profileImagePath": "/uploads/doctors/priya-nair.png",
  "isActive": true,
  "availableSlots": []
}
```

PUT /api/doctors/{id}

- Access: `Admin`
- Purpose: update an existing doctor profile

Request body:

```
{
  "fullName": "Dr. Priya Nair",
  "specializationId": 3,
  "city": "Chennai",
  "experienceYears": 9,
  "consultationFee": 650.0,
  "consultationStartTime": "10:00:00",
  "consultationEndTime": "14:00:00",
  "slotDurationMinutes": 30,
  "profileImagePath": "/uploads/doctors/priya-nair.png",
  "isActive": true
}
```

Success response:

```
{
  "doctorId": 7,
  "fullName": "Dr. Priya Nair",
  "specializationId": 3,
  "specializationName": "Dentist",
  "city": "Chennai",
  "experienceYears": 9,
  "consultationFee": 650.0,
  "averageRating": 0,
  "totalReviews": 0,
  "consultationStartTime": "10:00",
```

```
  "consultationEndTime": "14:00",
  "slotDurationMinutes": 30,
  "profileImagePath": "/uploads/doctors/priya-nair.png",
  "isActive": true,
  "availableSlots": []
}
```

DELETE /api/doctors/{id}

- Access: `Admin`
- Purpose: deactivate a doctor profile from the active directory

Success response:

```
{
  "message": "The doctor's record has been successfully removed."
}
```

Appointment APIs

GET /api/appointments

- Access: `Authenticated`
- Purpose: return appointments for the current user, or all appointments when the caller is an admin

Query parameters:

Name	Type	Required	Notes
`appointmentStatus`	string	no	`Booked`, `Confirmed`, `Completed`, or `Cancelled`
`pageNr`	int	no	default `1`
`pageSizeLimit`	int	no	default `10`

Success response:

```
{
  "pageNumber": 1,
  "pageSize": 10,
  "totalRecords": 1,
  "items": [
    {
      "appointmentId": 101,
      "userId": 2,
      "userName": "Harsh Raj",
```

```
      "doctorId": 1,
      "doctorName": "Dr. Ananya Mehta",
      "appointmentDate": "2026-03-24",
      "timeSlot": "09:30",
      "status": "Booked",
      "reasonForVisit": "Routine heart check-up",
      "cancellationReason": null,
      "canRate": false
    }
  ]
}
```

POST /api/appointments/book

- Access: `Authenticated`
- Purpose: book an appointment for the current user

Request body:

```
{
  "doctorId": 1,
  "appointmentDate": "2026-03-24",
  "timeSlot": "09:30",
  "reasonForVisit": "Routine heart check-up"
}
```

Success response:

```
{
  "message": "Your medical appointment has been successfully
        scheduled.",
  "appointment": {
    "appointmentId": 101,
    "userId": 2,
    "userName": "Harsh Raj",
    "doctorId": 1,
    "doctorName": "Dr. Ananya Mehta",
    "appointmentDate": "2026-03-24",
    "timeSlot": "09:30",
    "status": "Booked",
    "reasonForVisit": "Routine heart check-up",
    "cancellationReason": null,
    "canRate": false
  }
}
```

Conflict response:

```
{
  "message": "The chosen time slot has already been reserved by another
        patient."
}
```

DELETE /api/appointments/{id}

- Access: `Authenticated`
- Purpose: cancel an appointment as the owner or as an admin
- Optional query parameter: `cancellationReason`

Example request:

```
DELETE /api/appointments/101?cancellationReason=Schedule%20changed
```

Success response:

```
{
  "message": "The selected appointment has been cancelled."
}
```

PUT /api/appointments/{id}/status

- Access: `Admin`
- Purpose: update an appointment status centrally from the admin workflow

Request body:

```
{
  "status": "Completed",
  "cancellationReason": null
}
```

PUT /api/appointments/{id}/reschedule

- Access: `Authenticated`
- Purpose: reschedule an appointment to a new date/time

Request body:

```
{
  "appointmentDate": "2026-03-25",
  "timeSlot": "10:30",
  "reasonForVisit": "Follow-up consultation"
}
```

Success response:

```
{
  "appointmentId": 101,
  "userId": 2,
  "userName": "Harsh Raj",
  "doctorId": 1,
  "doctorName": "Dr. Ananya Mehta",
  "appointmentDate": "2026-03-25",
  "timeSlot": "10:30",
```

```
  "status": "Booked",
  "reasonForVisit": "Follow-up consultation",
  "cancellationReason": null,
  "canRate": false
}
```

Rating APIs

POST /api/ratings

- Access: `Authenticated`
- Purpose: submit a rating for a completed appointment owned by the current user

Request body:

```
{
  "appointmentId": 101,
  "doctorId": 1,
  "ratingValue": 5,
  "reviewComment": "Very professional and explained the treatment
        clearly."
}
```

Success response:

```
{
  "message": "Your feedback has been submitted successfully.",
  "data": {
    "ratingId": 21,
    "userName": "Harsh Raj",
    "ratingValue": 5,
    "reviewComment": "Very professional and explained the treatment
        clearly.",
    "createdAtUtc": "2026-03-25T09:45:00Z"
  }
}
```

Validation failure:

```
{
  "message": "Rating can only be submitted for completed appointments."
}
```

User Administration APIs

GET /api/users

- Access: `Admin`
- Purpose: return a paginated user directory

Example request:

```
GET /api/users?pNum=1&pSize=10
```

Success response:

```
{
  "pageNumber": 1,
  "pageSize": 10,
  "totalRecords": 2,
  "items": [
    {
      "userId": 2,
      "fullName": "Harsh Raj",
      "email": "user@fracto.com",
      "role": "User",
      "city": "Bengaluru",
      "isActive": true,
      "createdAtUtc": "2026-03-13T09:20:00Z"
    }
  ]
}
```

PATCH /api/users/{id}/toggle-status

- Access: `Admin`
- Purpose: toggle a user between active and inactive states

Success response:

```
{
  "message": "The user account status has been successfully modified."
}
```

GET /api/users/{id}

- Access: `Admin`
- Purpose: fetch a single user record for admin editing

POST /api/users

- Access: `Admin`
- Purpose: create a new user account (admin or user)

PUT /api/users/{id}

- Access: `Admin`
- Purpose: update an existing user

DELETE /api/users/{id}

- Access: `Admin`
- Purpose: deactivate a user account

Success response:

```
{
  "message": "User account has been deactivated."
}
```

Common Status Codes

Status	Meaning
`200 OK`	successful read, login, cancellation, toggle, or rating submission
`201 Created`	successful doctor creation
`400 Bad Request`	validation or request format problem
`401 Unauthorized`	missing or invalid JWT
`403 Forbidden`	authenticated but not allowed to access the resource
`404 Not Found`	requested entity does not exist
`409 Conflict`	duplicate email or slot/rating conflict
`500 Internal Server Error`	unexpected server-side failure

Related Documentation

- JWT_Authentication_Flow.md
- ER_Diagram.md
- Database_Design.md
- Fracto_Project_Report.md